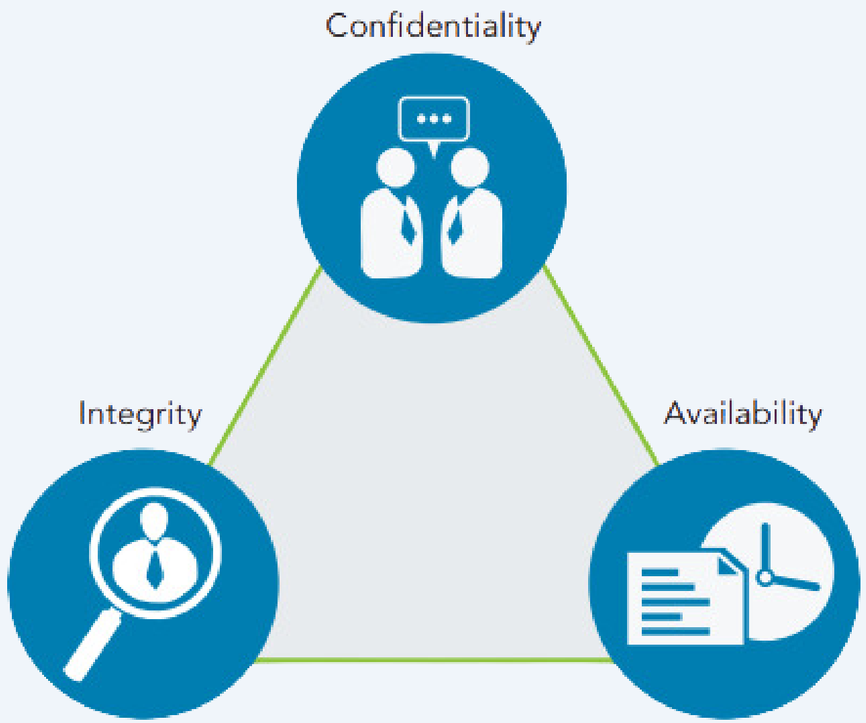
Security Principles

PRESENTATION BY HARSHIT BHARDWAJ

CIA



Confidentiality: Protects sensitive data from unauthorized access. This includes limiting access to authorized individuals, using passwords, locks, and tokens, classifying, labeling, or encrypting data, and implementing multi-factor authentication systems.

Integrity: Keeps data safe from unnecessary changes. This includes tracking and limiting who can make changes, using encryption, digital signatures, and hashing.

CIA

Availability: Ensures that data and systems are accessible. This can be ensured through network, server, application, and service redundancy, hardware fault tolerance in servers and storage, and other countermeasures.

Some Definations

Threat: A cyber threat is a malicious act that seeks to steal or damage data or discompose the digital network or system. Threats can also be defined as the possibility of a successful cyber attack to get access to the sensitive data of a system unethically. Examples of threats include computer viruses, Denial of Service (DoS) attacks, data breaches, and even sometimes dishonest employees.

Some Definations

Threats could be of three types, which are as follows:

1. Intentional- Malware, phishing, and accessing someone’s account illegally, etc. are examples of intentional threats.
2. Unintentional- Unintentional threats are considered human errors, for example, forgetting to update the firewall or the anti-virus could make the system more vulnerable.
3. Natural- Natural disasters can also damage the data, they are known as natural threats.

Some Definations

Vulnerability: In cybersecurity, a vulnerability is a flaw in a system’s design, security procedures, internal controls, etc., that can be exploited by cybercriminals. In some very rare cases, cyber vulnerabilities are created as a result of cyberattacks, not because of network misconfigurations. Even it can be caused if any employee anyhow downloads a virus or a social engineering attack.

Some Definations

Risk: Cyber risk is a potential consequence of the loss or damage of assets or data caused by a cyber threat. Risk can never be completely removed, but it can be managed to a level that satisfies an organization’s tolerance for risk. So, our target is not to have a risk-free system, but to keep the risk as low as possible.

Types of Risks

There are two types of cyber risks, which are as follows:

1. External- External cyber risks are those which come from outside an organization, such as cyberattacks, phishing, ransomware, DDoS attacks, etc.

2. Internal- Internal cyber risks come from insiders. These insiders could have malicious intent or are just not be properly trained.

Information Security

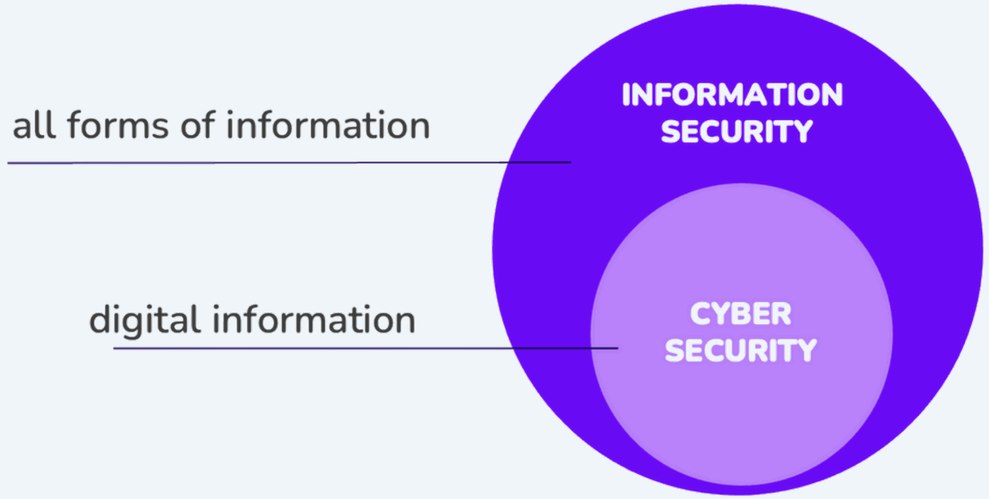
Information Security

Information security, often referred to as InfoSec, refers to the processes and tools designed and deployed to protect sensitive business information from modification, disruption, destruction, and inspection.

CyberSecurity vs Information Security

Information Security

Information security (InfoSec) protects all forms of information, digital and physical. Cybersecurity protects all forms of digital information, including computers, handheld devices, cloud, and networks, and can be considered a subset of InfoSec.



Goals of Information Security

- **Confidentiality**

Protects information from unauthorized disclosure

- **Integrity**

Protects information from unauthorized changes

- **Availability**

Protects authorized access to systems and data

Ensures information is available to authorized users

Confidentiality Concern

Confidentiality Concerns

- **Snooping**

Involves gathering information that is left out in the open

------> Clean desk policies protect against snooping

- **Dumpster Diving**

Looking through trash for information

------> Shredding protects against Dumpster Diving

Confidentiality Concerns

Confidentiality Concerns

- **Wiretapping**

Electronic Eavesdropping

------> Encryption protects against wiretapping

- **Social Engineering**

Attacker uses psychological tricks to persuade employee to give it or give access to information

------> Education and Training protects against social engineering

Integrity Concern

Integrity Concerns

- **Unauthorized Modification**

Attackers make changes without permission (can be internal=employees or external

-------> Follow the Rules of Least Privilege to prevent unauthorized modification

- **Impersonation**

Attackers pretend to be someone else

-------> User education protects against Impersonation

Integrity Concerns

- Man-in-the-Middle (MITM)

Attackers place the themselves in the middle of communication sessions
Intercepts network traffic as users are logging in to their system and assumes their role.

---------> Encryption prevents man-in-the-middle attacks

- Replay

Attackers eavesdrop on logins and reuse the captured credentials

---------> Encryption prevents Replay attacks

Integrity Concerns

How Man In The Middle of Network Works

Availability Concerns

Availablity Concerns

- Power Outages

------> Having redundant power sources and back-up generators protect against power outages

- Hardware Failures

Failure of servers, hard drives, network gear etc

------> Redundant components protect against hardware failure

------> Building systems that have a built-in redundancy, so that if one component fails, the other will take over

Availablity Concerns

- Destruction

-------> Backup data centers protect against destruction (ex=cloud)

- Service Outages

Service outage may occur due to programming errors, failure of underlying equipment, and many more reasons

-------> Building systems that are resilient in the fact of errors and hardware failures protect against service outages

Authentication & Authorization

Access Control Process

- **Identification**

Identification involves making a claim of identity (Can be false)

------> Electronic identification commonly uses usernames

- **Authentication**

Authentication requires proving a claim of identity

------> Electronic authentication commonly uses passwords

Access Control Process

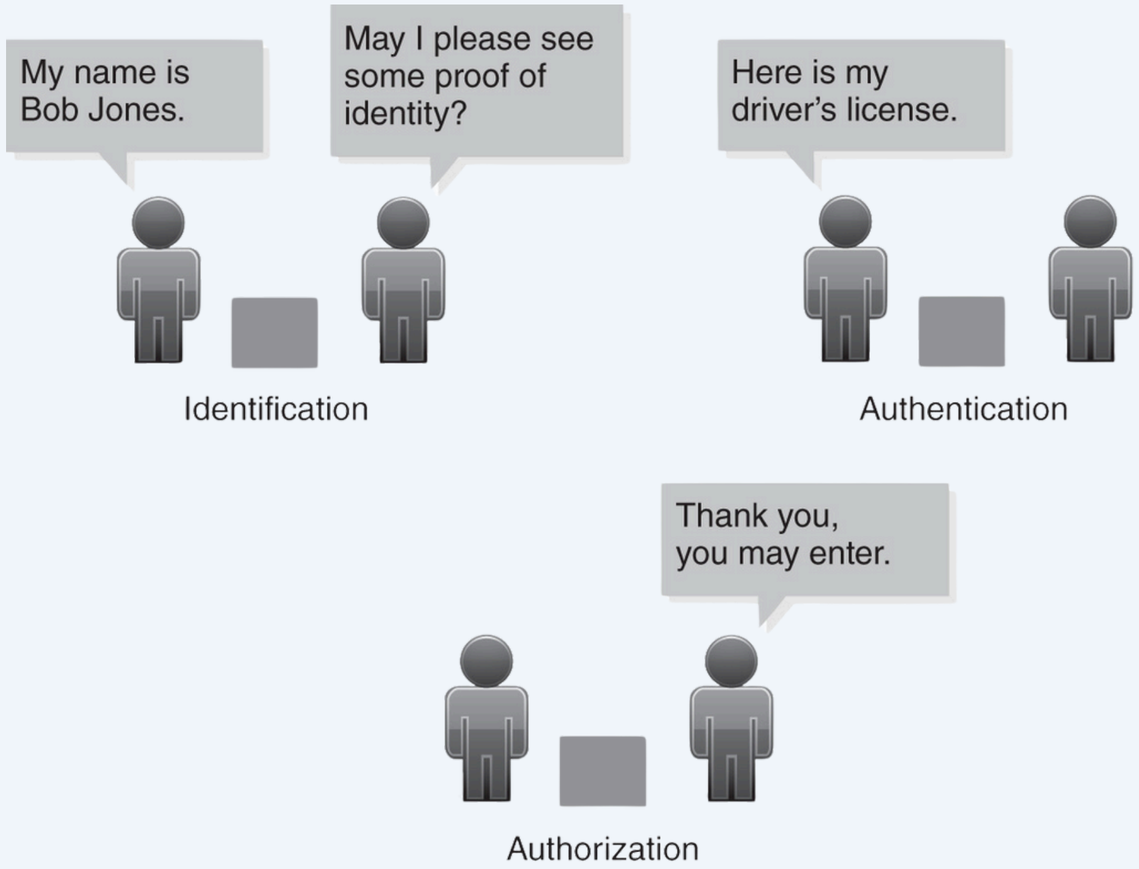
- **Authorization**

Authorization ensures that an action is allowed

-----> **Electronic authorization commonly takes the form of access control lists**

- **Accounting**

Accounting keeps track of user activity while users are logged in to a network by tracking information such as how long they were logged in, the data they sent or received, their Internet Protocol (IP) address, the Uniform Resource Identifier (URI) they used, and the different services they accessed.


My name is Bob Jones.
May I please see some proof of identity?
Here is my driver's license.
Thank you, you may enter.
Identification
Authentication
Authorization

Access Control Process

IDENTITY

Who do you claim to be?

AUTHENTICATION

Are you really who you claim to be?

AUTHORIZATION

What are you allowed to do?

ACCOUNTING

What did you actually do?

Password Security

- **Controls you can implement when setting password requirements:**

Password length requirements

Password complexity requirements

Password expiration requirements

---->Force password changes

Password history requirements

---->Cannot use previously used passwords

Multi Factor Authentication

What are the 3 types of authentication factors?

Multi Factor Authentication

- Something you know
- Something you have
- Something you are

You combine these factors all together = Multi Factor Authentication

Multi Factor Authentication

Something you
KNOW

Password or phrase
PIN

Something you
HAVE

Code from app or SMS
Push notification
USB token

Something you
ARE

Finger or thumb print
Face scan
Iris scan

Non-Repudiation

Prevents someone from denying the truth

- Physical signatures can provide non-repudiation on contracts, receipts etc
- Digital signatures use encryption to provide non-repudiation
- Other methods can be biometric security controls, Video-surveillance etc

Organization Privacy Concerns

Protecting our down data

- Protect your down organizations data

Educating on users

- Educated users of how they can protect their own personal information

Protecting data collected by our organizations

- Protecting data that was entrusted to the organization (ex= client's data)

Types of Private Information

2 Types of Private Information

1. Personally-Identifiable Information (PII)
   - Any information that can be tied back to a specific individual
2. Protected Health Information (PHI)
   - Health care records
   - Regulated by HIPPA

Threat + Vulnerability = Risk

Ranking of Risks

We rank risks by likelihood and impact

- Likelihood

Probability a risk will occur

- Impact

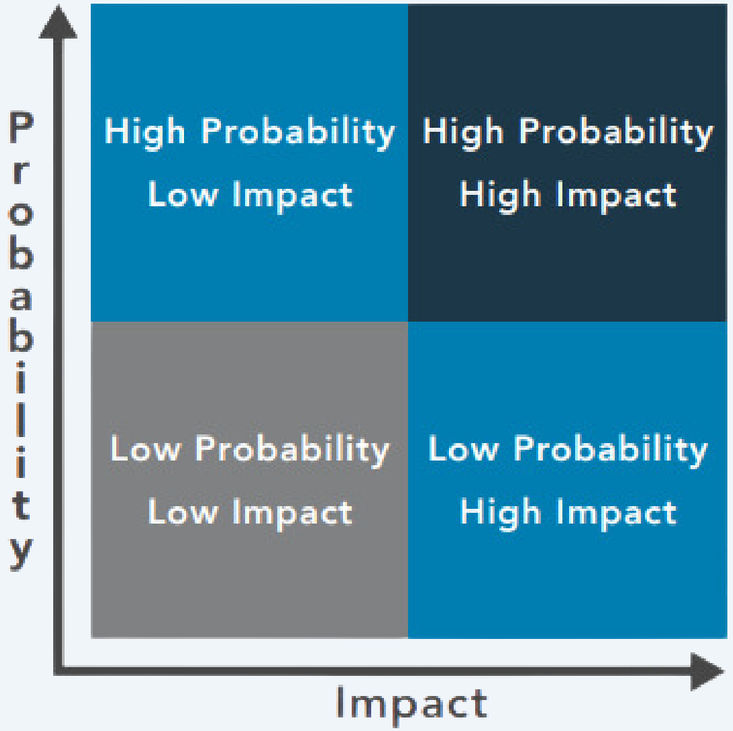
Amount of damage a risk will cause

Risk Assessment

A cyber security risk assessment is a process that evaluates an organization's defenses against cyber threats. It helps identify and quantify vulnerabilities, and determine the likelihood and impact of each threat. The result of the assessment is a prioritized list of vulnerabilities that the organization can address.

A cyber security risk assessment can help organizations: Reduce long-term costs, Avoid data breaches, Avoid regulatory issues, Avoid application downtime, and Avoid data loss.

Prioritizing Risk



You can use this simple probability and impact model to determine the level of risk and therefore prioritize risk. You can assign numbers to the level of probability and impact. For example, a risk with a high probability and high impact can be represented by a 1, low probability and high impact a 2, high probability and low impact a 3, and low probability and low impact a 4. This would put the risks in priority order, with 1s being your first priority and 4s being your last priority.

Example Assessment

- **Phishing Attacks**

Likelihood: High

Impact: Medium

- **Ransomware**

Likelihood: Medium

Impact: High

- **Zero-day Vulnerabilities**

Likelihood: Low

Impact: Medium

- **Denial-of-Service (DoS) Attacks**

Likelihood: Medium

Impact: Low

4 Types of Risk Treatment

1. Risk Avoidance
   - Changes business practices to make a risk irrelevant

2. Risk Transference
   - Attempting to shift the impact of a risk from your organization to another organization
   - Example : Insurance policy
   - Note that you cannot always transfer the risk completely. Reputation damage etc.

4 Types of Risk Treatment

3. Risk Mitigation

Actions that reduce the likelihood or impact of a risk

4. Risk Acceptance

Choice to continue operations in the face of a risk

Risk Acceptance

This approach will not reduce the impact of a risk or even prevent it from happening, but that’s not necessarily a bad thing. Sometimes the cost of mitigating risks can exceed the cost of the risk itself, in which case it makes more sense to simply accept the risk. After all, why spend £200,000 to prevent a £20,000 risk?

t is best to accept risks only when the risk has a low chance of occurring or will have minimal impact if it does occur.

Example: Management formally accepts the risk of a low-impact internal vulnerability due to high remediation cost and minimal business impact.

Risk Avoidance

Avoidance involves identifying potential risks and taking proactive measures to avoid or eliminate them. This method is applied when the level of risk is too high, and the cost of mitigation outweighs the potential benefits. It may include refraining from using vulnerable software or discontinuing activities that pose significant cybersecurity risks.

Example: The organization decommissions a legacy application running on an unsupported OS to completly eliminate the associated security risk.

Risk Mitigation

Mitigation aims to decrease the likelihood or impact of identified cybersecurity risks. This method involves implementing security controls, such as firewalls, intrusion detection systems, and encryption. By reducing exposure to potential threats, organizations can effectively manage the level of risk and minimize the likelihood of security incidents.

Example: Multi-factor authentication and least-privilege access are implemented to reduce the likelihood of unauthorized access to critical systems.

Risk Transference

Attempting to shift the impact of a risk from your organization to another organization. The risk still exists, only the responsibility for it shifts from your organisation to another.

An example of this would be travel insurance. You don’t accept the risk of a lost suitcase or an accident abroad and the costs that this would bring – you pay a travel insurance company to bear the financial consequences for you.

Cyber Insurance

Access Management

Access Management – Principle of Least Privilege

- Users granted only the access required for their job role
- Administrative access provided on approval basis only
- Role-Based Access Control (RBAC) enforced
- Temporary or Just-In-Time privileged access
- Periodic access review and timely revocation

Outcome: Reduced attack surface and insider risk

Access Management – Separation of Duties

- Critical tasks divided across multiple roles
- No single user controls request, approval, and execution
- Independent review for system and security changes
- Documented approvals for exceptions

Example: Developer ≠ Deployer ≠ Approver

Backup Strategy – Backup Types

- **Full Backup:** Complete copy of all data
- **Incremental Backup:** Data changed since last backup
- Full backups used as baseline
- Incremental backups reduce storage and time

Goal: Efficient and reliable data recovery

Backup Strategy – 3-2-1 Rule

- Maintain **3 copies** of critical data
- Store backups on **2 different media types**
- Keep **1 copy offsite or offline**

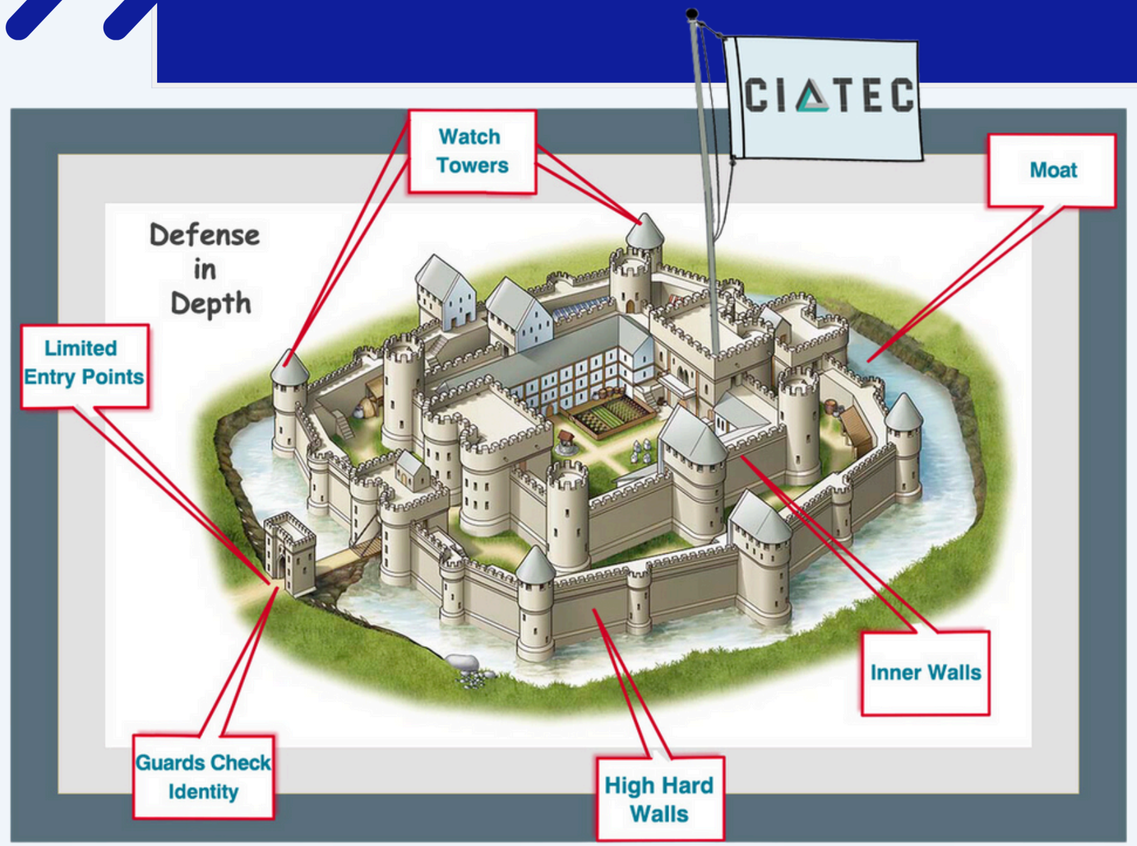
Purpose: Protection against ransomware and disasters

Backup Security & Monitoring

- Backup data encrypted at rest and in transit
- Access to backups restricted and logged
- Regular restore testing to validate backups
- Monitoring and alerts for backup failures

Ensures: Data availability and business continuity

Defense in Depth



- Uses overlapping security controls
- Different methods of security with a common objective

OUTSIDE THREAT PROTECTION
PERIMETER SECURITY
DMZ
VPN
2FA/MFA
IDS/IPS
WAF
Web Content Filter
Honeypot
NETWORK SECURITY
VoIP Security
Wireless Security
Firewall
Virtual Patching
Mobile Security
External Vuln Scanning
Message Security
Internal IDS/IPS
ENDPOINT SECURITY
NAC
DLP
NGAV/EDR/MDR (malware/ransomware)
File Integrity Monitoring
Internal Vuln Scanning
DDos Prevention
Internal Firewall
Patch Management
Physical Security
Endpoint App White/Blacklist
APPLICATION SECURITY
Endpoint Disk Encryption
ICAM/ZTA (2FA/MFA)
Network Device Hardening
Application Vuln Scanning
Dynamic App Testing
DLP
Endpoint Firewall
Physical Security
Logging
Endpoint Hardening
Database Security
DATA SECURITY
Static App Testing
ICAM/ZTA (2FA/MFA)
WAF
ICAM/ZTA (2FA/MFA)
Logging
ICAM/ZTA (2FA/MFA)
Data Classification
DLP
Continuous C&A
Data Integrity Monitoring
CSIRT
IT Security Governance
Security Plan
Data/Drive Encryption
Data Wiping
Focused Ops
SIEM
PKI
DLP
Logging
Security Dashboard
Digital Forensics
Vulnerability Assessment
Business Continuity Plan
SOC/NOC Monitoring (24x7)
Escalation Management
Security Awareness Training
IT Disaster Recovery Plan
Continuous Monitoring & Assessement
Security SLA/SLO Reporting
Security Architecture & Design
Risk Management
Situational Awareness
Security Policies & Compliance
Data Classification
Penetration Testing
Cyber Threat Intelligence
MISSION CRITICAL ASSETS
POLICY MANAGEMENT & PREVENTION
MONITORING & RESPONSE / OPERATIONS
DEFENSE-IN-DEPTH MODEL
COLOHOUSE

Physical Security

- Objective: Protect the physical components of your IT infrastructure.

- Examples: Security guards, surveillance cameras, locked server rooms, biometric access controls.

Network Security

- Objective: Safeguard the network from unauthorized access and attacks.

- Examples: Firewalls, intrusion detection/prevention systems (IDS/IPS), virtual private networks (VPNs), network segmentation.

Endpoint Security

- Objective: Protect individual devices that connect to the network.

- Examples: Antivirus software, endpoint detection and response (EDR) tools, patch management, device encryption.

Application Security

- Objective: Secure applications to prevent exploitation of vulnerabilities.

- Examples: Web application firewalls (WAFs), secure coding practices, application security testing, regular software updates.

Data Security

- Objective: Protect the data from unauthorized access and breaches.

- Examples: Data encryption (at rest and in transit), access controls, data masking, regular backups.

Identity and Access Management (IAM)

- Objective: Ensure that only authorized users have access to systems and data.

- Examples: Multi-factor authentication (MFA), single sign-on (SSO), role-based access control (RBAC), user provisioning and de-provisioning.

Policies and Procedures

- Objective: Establish guidelines and protocols for secure operations.
- Examples: Security policies, incident response plans, regular security training and awareness programs, compliance with regulations.

Monitoring and Detection

- Objective: Continuously monitor systems to detect and respond to security incidents.

- Examples: Security information and event management (SIEM) systems, continuous monitoring, log management, anomaly detection.

Example Scenario

Imagine a scenario where an attacker tries to breach an organization's network:

- Physical Security: The attacker cannot physically access the server room due to biometric locks and security guards.
- Network Security: The attacker tries to penetrate the network but is blocked by the firewall and detected by the IDS/IPS.
- Endpoint Security: The attacker targets an employee's workstation, but the antivirus and EDR tools prevent malware execution.

Example Scenario

- Application Security: The attacker attempts to exploit a web application vulnerability, but the WAF blocks the malicious request.
- Data Security: Even if the attacker manages to access some data, it is encrypted and thus unusable without the decryption key.
- IAM: The attacker cannot escalate privileges due to strong MFA and RBAC policies.

Example Scenario

- Policies and Procedures: The organization has an incident response plan in place, so they quickly identify and isolate the breach.

- Monitoring and Detection: Continuous monitoring detects unusual activity, triggering an immediate investigation and response.

Thank you

PRESENTATION BY HARSHIT BHARDWAJ